



CÁTEDRA INCIBE
Digitalización y Ciberseguridad Hídrica

Gestión de la ciberseguridad hídrica: la opinión de los profesionales del sector

Dra. Laura Arantegui Arràez

Dr. Steven Kemp

Dr. Ignasi Rodriguez-Roda Layret



ÍNDICE

1. INTRODUCCIÓN	3
2. ASPECTOS GENERALES DE CIBERSEGURIDAD	4
2.1. LA CIBERSEGURIDAD COMO PRIORIDAD	4
2.2. LOS CIBERATAQUES Y LA CONCIENCIA DE RIESGO	4
2.3. LA GESTIÓN DE LA CIBERSEGURIDAD	6
3. EXPERIENCIAS PROPIAS EN LA GESTIÓN	9
3.1. DIGITALIZACIÓN Y CIBERSEGURIDAD	9
3.2. UN OBSTÁCULO RECURRENTE: IT VS. OT. LOS RIESGOS.	11
4. CUMPLIMIENTO NORMATIVO	14
4.1. LA NORMATIVA APLICABLE	14
4.2. LA ESPERADA NIS2	14
4.3. RETOS DE FUTURO. ¿CÓMO MEJORAR LA CIBERSEGURIDAD HÍDRICA?	16
5. CONCLUSIONES Y RECOMENDACIONES	17



1.Introducción

La ciberseguridad ha sido -y seguirá siendo- objeto de múltiples estudios y análisis. No puede afirmarse lo mismo de la ciberseguridad aplicada al ciclo del agua. Aun cuando puede encontrarse material de tipo mayoritariamente técnico, es difícil disponer de información actualizada sobre la situación del sector en general, como las principales inquietudes y retos, necesidades identificadas o el cumplimiento normativo.

Para ello, desde la Cátedra, hemos realizado hasta 15 entrevistas con profesionales del sector con el fin de responder a tres cuestiones generales:

1. ¿Cuáles son las principales amenazas para la ciberseguridad en el sector del agua?
2. ¿Cómo se caracteriza la gestión la ciberseguridad en el sector del agua?
3. ¿Qué normas son más relevantes y que retos supone cumplirlas?

Los entrevistados, a los que se garantizó el anonimato, provienen de entidades muy diversas que abarcan en la mayoría de ocasiones todo el ciclo del agua, y que desarrollan su actividad a nivel comarcal, nacional e internacional.

Agradecemos la buena disposición y la colaboración de todos los participantes.

En las entrevistas nos han hablado sobre aspectos generales de ciberseguridad, sobre la gestión que realizan específicamente en su entidad, y finalmente sobre aspectos normativos. Su punto de vista es crucial para emprender acciones orientadas a cubrir las necesidades reales del sector. Como respuesta a una serie de materias fundamentales, presentamos a continuación las opiniones recogidas, destacando algunas citas literales.



2. Aspectos generales de ciberseguridad

2.1. La ciberseguridad como prioridad

La ciberseguridad debe ser una de las prioridades de las entidades del sector, puesto que se realiza una actividad crítica. Puede matizarse que en realidad la prioridad es dar servicio a los usuarios, y que la ciberseguridad es relevante en la medida en que puede hacer que ese servicio se vea comprometido, por tanto **debe tenerse en cuenta en cada decisión**.

“Falta mucha cultura de la seguridad informática. Mucha, mucha, mucha. Yo creo que es el gran problema que hay a todos los niveles.”

“Si le preguntas al CEO de la compañía te va a decir que no, que la ciberseguridad es muy cara, que es un riesgo, pero que somos pequeños, que no pasa nada”.

2.2. Los ciberataques y la conciencia de riesgo

Los ataques **más frecuentes** son los que tiene que ver con **phishing**, estafas, robo de datos y **ransomware**. Los que se consideran como ataques de **mayor impacto** son los que **afectan a las infraestructuras OT**.

“Si es un cifrado, un ataque a la compañía a nivel de infraestructura, pues es un daño económico muy alto, pero no tiene un impacto en la sociedad”.

“La gente si le preguntas qué prefieres, que... que te corten el agua o que te roben los datos personales, la gente dice: ‘¡no, no me cortes el agua!’”.

LOS CIBERATAQUES...

- **...MÁS FRECUENTES SON:**
Phishing, estafas, robo de datos y *ransomware*.
- **...DE MAYOR IMPACTO SON:**
Afectación a la composición o al suministro del agua.

Hay un riesgo real de ciberataques y la alarma en el sector **tiene el nivel adecuado**, aunque una parte de los entrevistados considera que hay **poca conciencia de riesgo**. Una minoría de participantes opina que el nivel de riesgo es bajo.



“Creo que la alarma que pueda existir es real. Y en todo caso, si hay por exceso o por defecto, (...) creo que suele ser por defecto, (...) no hay suficiente conciencia de la de la posibilidad real de un ataque”.

“Es una amenaza muy real, y que debería tomarse mucho más en serio y después bueno, como siempre, la administración, no sé si hace el trabajo”.

EL RIESGO ES REAL. ADEMÁS:

- **A MAYOR CONECTIVIDAD, MÁS POSIBLES ATAQUES.**
- **FALTA CONCIENCIA DE RIESGO.**

El entorno OT es el más desprotegido porque son instalaciones muy dispersas geográficamente y en algunos casos utilizan tecnología desfasada. Eso afecta a la cadena de suministro, porque un ataque a estas infraestructuras podría interrumpir el servicio o comprometer la calidad del agua. Asimismo, las plantas de agua no tienen trabajadores suficientes para realizar inventarios.

“Tecnología que no se había diseñado, pensado teniendo en cuenta la seguridad... Y la seguimos utilizando porque es que no queda otra, no? (...) Hay esa parte de... de de activos más Legacy que están más desprotegidos”.

La cadena de suministro no está suficientemente controlada. Por una parte, porque depende del proveedor con el que se contrate, y por otra a causa de las características de los elementos OT.

“No es lo mismo contratar con un Deloitte que contratar con Suministros Paco. (...) el control pasa, en nuestro caso, por nosotros”.

“Si al final son sistemas manuales (...) no hay forma física de de manipularlo de forma remota (...). Lo que sí está claro es que la tendencia al final es que cada vez los dispositivos estén más controlados”.



LA CADENA DE SUMINISTRO...

- ...NO ESTÁ SUFICIENTEMENTE CONTROLADA.
- EL ENTORNO OT ES EL MÁS DESPROTEGIDO.

2.3. La gestión de la ciberseguridad

La digitalización en el sector no se ha realizado paralelamente a la inversión en **ciberseguridad**. La razón no es solamente **falta de recursos**, sino también, y de un modo muy decisivo, la **falta de concienciación en ciberseguridad**.

“Sí que se está viendo que (...) los recursos cada vez son mejores, pero claro, eso no va acorde con el incremento exponencial que está habiendo”.

“Desde la propia administración a través de sus licitaciones, no tienen consideración la ciberseguridad” (...) si no lo tienen en consideración, pues es difícil que el proveedor del servicio lo vaya a priorizar”.

Asimismo, la gestión de **la seguridad de las infraestructuras físicas debe realizarse conjuntamente con la de la ciberseguridad**, a pesar de que la gestión de las infraestructuras físicas tiene características específicas.

“No será ‘la infraestructura OT, la infraestructura IT’. No, no, será ‘la infraestructura’”.

Las auditorías, tanto internas como externas, son fundamentales para que la entidad pueda gestionar la ciberseguridad. En particular las externas son una vía de aprendizaje y mejora continua.

“Con las externas aprendes mucho, (...) está muy bien que te venga alguien de fuera porque el de fuera sabe mucho y después siempre te da consejos. Siempre encuentra cosas”.

“Las auditorías nos permiten tener partida presupuestaria y no solo mejorar, sino también tener una parte económica para poder dar ese salto”.



LA INVERSIÓN EN CIBERSEGURIDAD:

- NO HA ESTADO A LA ALTURA DEL AVANCE EN DIGITALIZACIÓN.
- DEBE CONTEMPLAR CONJUNTAMENTE LOS ENTORNOS IT Y OT.
- PUEDE APOYARSE EN LAS AUDITORÍAS EXTERNAS.

La **formación en ciberseguridad** en las entidades del sector **es imprescindible** y debe **adaptarse a las características de cada rol**. Son especialmente importantes la concienciación de los usuarios sobre los riesgos, y la **formación cruzada** de los responsables IT en materia de OT, y viceversa. **Es clave que la Dirección participe en las formaciones** cuando sean abiertas a todos, ya que esta actitud sitúa la ciberseguridad como un interés básico de la entidad y contribuye a que haya un mayor interés en cumplir con sus requisitos.

“Con respecto a trabajadores OT... (...) la labor para que hay que hacer es abismal. (...) porque no hay conciencia de que esos dispositivos (...) pueden ser susceptibles de ataque”.

“La Dirección debe ser la primera implicada efectivamente (...). Si viene de arriba hacia abajo, la gente se lo coge más en serio”.

LAS ACCIONES FORMATIVAS:

- DEBEN ESTAR DIFERENCIADAS SEGÚN EL ROL DEL RECEPTOR.
- DEBEN INCLUIR FORMACIÓN EN SEGURIDAD IT Y OT.
- DEBEN IMPLICAR ACTIVAMENTE A LOS EQUIPOS DIRECTIVOS.

Sería deseable que un **profesional de la ciberseguridad hídrica** reuniera dos características principales: el **conocimiento conjunto del negocio y de la operativa** y, sobre todo, el don de gentes, la **capacidad de comunicación y la flexibilidad**. Trasladar la preocupación por la ciberseguridad requiere no solamente saber comunicar, sino saber hacerlo de manera adaptada a cada rol dentro de la organización.

“Un responsable de seguridad tiene que ser cercano.(...) Lo tienen que ver como un soporte más que como una persona que les impone, les marca, ¿no? Limitaciones”.



“Tiene que ser muy versátil y tener un poco la doble gorra” (...) un problema muy grave que tenemos es la ausencia de profesionales en ciberseguridad formados en el mundo del agua, que conozcan la problemática de nuestros sistemas, sobre todo industriales, que son complejos”.

EL MEJOR PROFESIONAL DEL SECTOR ES EL QUE:

- **CONOCE TÉCNICAS PARA NEUTRALIZAR ATAQUES.**
- **SABE MANEJARSE POR LA “DEEP WEB”.**
- **CONOCE EL NEGOCIO Y LA OPERATIVA.**
- **ES CERCANO Y SABE COMUNICAR.**
- **ADAPTA EL MENSAJE AL ROL DE CADA INTERLOCUTOR.**

La gestión de la ciberseguridad hídrica **no se diferencia mucho de la del resto de actividades críticas**, pero tiene peculiaridades, como la **rigidez de la normativa** aplicable, la orientación prioritaria en la **disponibilidad del recurso**, y el gran peso de las **infraestructuras industriales**.

“Se diferencia, y se debe diferenciar, porque estamos más centrados en la disponibilidad, más que en la confidencialidad”.

“La parte específica (...) es la parte industrial que tenemos” (...) no podemos parar de suministrar el agua, sin embargo una fábrica de coches por muy grande que sea puede parar, no pasa nada”.



ASPECTOS GENERALES: RESUMEN.

- ⇒ El riesgo es real, pero no hay suficiente conciencia de ese riesgo.
- ⇒ Los ciberataques más frecuentes son los de *phishing*, estafas, robo de datos y *ransomware*.
- ⇒ Los ciberataques más graves son los que afectan a las infraestructuras OT.
- ⇒ El entorno OT es el más desprotegido.
- ⇒ La cadena de suministro no está suficientemente controlada.
- ⇒ La digitalización se ha realizado sin incluir la suficiente inversión en ciberseguridad.
- ⇒ La seguridad física y la ciberseguridad deben gestionarse conjuntamente.
- ⇒ Las auditorías de ciberseguridad internas y externas son fundamentales.
- ⇒ Es clave que la Dirección participe en las acciones formativas.
- ⇒ Un profesional de la ciberseguridad hídrica debe:
 - conocer estrategias para neutralizar ataques.
 - conocer el negocio y la operativa.
 - tener capacidad comunicativa y flexibilidad.

3. Experiencias propias en la gestión

3.1. Digitalización y ciberseguridad

Las entidades del ciclo del agua **han incrementado mucho su nivel de ciberseguridad** en los últimos 5 años, y especialmente a partir de la distribución de fondos del **PERTE**. En algunos casos prevén un avance aún mayor próximamente.

“De no haber prácticamente nada a tener bastante controlado”.

“Hace 5 años teníamos un antivirus y ya está”.



“Había permisos a personas que hace diez años que no estaban en la organización”.

Entre las medidas implantadas la más destacada es la **concienciación de los empleados**. Otras que destacan los **sistemas de copias de seguridad**, los **firewalls y protección de emails**, servicios **SOC** y de análisis de logs” (**CIEM**), y la **segmentación** de la red.

“Tenemos un grupo de whatsapp, ¿no? que cuando alguien recibe algún mensaje de estos sospechosos, ¿no? de phishing, pues lo ponemos allí” (...) Estamos activos y concienciados y ocupados con la seguridad”.

Por otra parte, aunque se detecta **un interés creciente** en la ciberseguridad por parte de los **equipos directivos**, **no siempre es fácil** que ese interés **se traduzca en una asignación de recursos**.

Todas la entidades han apostado en mayor o menor medida por el trabajo en remoto, especialmente a partir de la necesidad originada por el COVID, que obligó a una implantación precipitada. La decisión sobre el despliegue del teletrabajo, en todo caso, no obedecerá a cuestiones de vulnerabilidad del sistema (que pueden ser previstas y gestionadas) sino a **aspectos organizativos**.

“Cada persona que la tienes conectada en remoto, pero que esta entrada dentro de tu red, tu organización, es un potencial vector de entrada”.

“Como decían en aquella película, ‘la vida se abre camino’. (...) Porque al final es la operativa la que le está mandando”.

EN LA GESTIÓN DIARIA...

- **LA CIBERSEGURIDAD SE HA INCREMENTADO EN 5 AÑOS.**
- **SE HA CONCIENCIADO MÁS A LOS EMPLEADOS.**
- **LOS FONDOS NEXT GENERATION PERMITIRÁN INVERTIR MÁS.**

La opinión más extendida es que **no hay suficiente información para gestionar la ciberseguridad**. Se destaca que **falta información de tipo normativo, técnico, y también de asesoramiento** para decidirse entre las distintas opciones de ciberseguridad. Sin embargo, en algún caso se ha destacado que lo único necesario es **tener una actitud proactiva y acceder a la información** que hay disponible en distintas fuentes.



“La falta (...) de un mínimo de conocimiento y de formación en ciberseguridad hace que ya, directamente, digamos, ni te metas”.

“Se nos hace muy difícil contrastar las soluciones que presentan diferentes proveedores de soluciones de ciberseguridad para cotejar la calidad de unas o de otras. Porque al final todo el mundo dice que la suya es la mejor”.

“Si yo me esperara a que entraran inputs, te diría (...) ‘me falta info’, pero si intentas rascar yo creo que... que tienes suficientes fondos para empaparte”.

Hay un compromiso de las entidades con la **formación en ciberseguridad**, aunque también hay carencias en este aspecto. Las acciones formativas realizadas son sobre todo **de tipo genérico** para todos los trabajadores, con **emails de concienciación repetitivos**, píldoras informativas y **envío de simulacros de phishing** para detectar qué personas caen en el engaño y posteriormente impartirles formación específica.

“La gente ya está atenta porque no apetece mucho tener que hacer 20 cursos de ciberseguridad”.

“Es como cuando subes al avión y te cuentan cincuenta mil veces lo mismo en el avión. (...) Ya tenemos al ‘azafato’ que le explica a toda la gente lo mismo cada vez, pero es que lo tenemos que hacer (...) porque es que al final la seguridad depende mucho de las acciones que hagan las personas”.

INFORMACIÓN Y FORMACIÓN

- **FALTA INFORMACIÓN TÉCNICA, LEGAL Y DE ASESORAMIENTO.**
- **SE REALIZAN ACCIONES FORMATIVAS, PERO NO SUFICIENTES.**

3.2. Un obstáculo recurrente: IT vs. OT. Los riesgos.

Los entornos IT y OT están en un punto de desarrollo muy distintos en cuanto a ciberseguridad. Algunas entidades gestionan ambos de manera conjunta y otras separadamente, pero en general **siempre hay una coordinación de los dos ámbitos**.

“Cada vez en el entorno OT (...) sobre todo en la parte más alto nivel, (...) al final no deja de estar inundado de dispositivos IT”.



“Los departamentos de IT y OT han hablado poco y esto es un problema, y para la ciberseguridad esto es un problema añadido”.

Las entidades disponen, en general, de inventario de activos IT. Sin embargo, **no disponen de inventario de activos OT**, o está en un estado muy poco avanzado. También está **pendiente de desarrollo en muchos casos la monitorización de ataques a los activos**, sobre todo OT.

Asimismo, **no suelen existir protocolos de comunicación de incidentes de ciberseguridad**, aunque en muchos casos sí **se efectúan auditorías internas**, ya sea anualmente o *ad hoc*.

“La gente responsable de infraestructuras y tal tiene cierta conciencia de que: ‘¡ostras, tenemos que ver cómo estamos!’, pero claro, (...) tiene que servir para algo”.

El ciberataque **más temido es el ransomware**. En segundo lugar encontramos el acceso a los sistemas SCADA, y en general al entorno OT. Aunque **las medidas de seguridad implantadas podrían paliar dichos ataques**, al menos en el entorno IT, es algo que **no se puede afirmar con total seguridad**.

“Hasta que no te encuentras en la situación no sabes si realmente todo lo que has ido haciendo sirve o no sirve. (...) Yo soy de los que piensa (...) que tendremos que encontrarnos en una situación de este tipo, seguro. Es como los motoristas, ¿no? ‘están los que se han caído y los que se van a caer’”

“El problema es (...) que te roban información y no hay ransomware ninguno... que te han robado todo lo que había ahí porque a alguien se le ocurrió... o tuvo un error y lo puso a disposición de todo el mundo”.

Hasta ahora no se han producido ciberataques graves. De entre los mencionados, destacan la **encriptación de ficheros** y los que tienen que ver con **suplantación de identidad**, ya sea falsificando datos como a través de robo de cuentas de correo. A pesar de las medidas de seguridad adoptadas, el principal vector de entrada para estos ataques puede continuar siendo **el error humano que permita un acceso indeseado al sistema**.



IT vs. OT. ENFRENTÁNDOSE AL RIESGO

- NO HAY INVENTARIO DE ACTIVOS OT, O ESTÁN POCO AVANZADOS.
- EL ATAQUE MÁS TEMIDO ES EL DE *RANSOMWARE*.
- EL PRINCIPAL VECTOR DE ENTRADA ES EL USUARIO.

EXPERIENCIAS PROPIAS: RESUMEN.

- ⇒ Las medidas de ciberseguridad se ha incrementado en los últimos 5 años.
- ⇒ De las medidas implantadas hasta ahora por las entidades destacan:
 - la concienciación de los empleados,
 - las copias de seguridad, y
 - la protección de emails.
- ⇒ En general, existen inventarios de activos IT. No es así en el caso de activos OT.
- ⇒ Los ciberataques más temidos son los de *ransomware*.
- ⇒ El principal vector de entrada es el usuario.
- ⇒ Para una correcta gestión de la ciberseguridad falta información:
 - de tipo técnico,
 - del ámbito normativo, y
 - de asesoramiento para elegir entre las diversas soluciones de ciberseguridad.
- ⇒ El éxito de la gestión depende directamente de la implicación de la Dirección.



4. Cumplimiento normativo

4.1. La normativa aplicable

La normativa aplicable en el sector es, esencialmente, el **Esquema Nacional de Seguridad” (ENS)**, el **Reglamento General de Protección de Datos” (RGPD)** y la **Directiva europea NIS2**, que llega tarde a su transposición, ya que debería haberse producido el 17/10/2024, aunque se ha publicado ya el borrador de la ley que deberá materializar dicha transposición. El ajuste a la normativa es una de las cuestiones que preocupan a las entidades.

“Todo el mundo está cumpliendo con el tema o intentando cumplir con el tema del ENS. Lo que sabemos es que hay muy pocos que lo estén cumpliendo”.

4.2. La esperada NIS2

El conocimiento general sobre el contenido de la NIS2 es muy superficial o inexistente. Se centran sobre todo en el cumplimiento del ENS, mientras esperan que se produzca la transposición de la nueva directiva. Por tanto, **no identifican muchas inquietudes o retos** que pueda representar la Directiva para la entidad. De entre los aspectos mencionados destacan **la gestión del ámbito OT, la gestión documental, el protocolo de notificación de incidentes y la afectación del sector de residuales**, que no estaba incluido en la directiva de seguridad anterior, la NIS1.

La llegada de la NIS2 se espera con optimismo porque puede ser un elemento más que **“obligue” a la Dirección** de las entidades a adoptar medidas de ciberseguridad.

“Al final hablamos de medidas en base al riesgo (...) entonces, claro, lo que tienes que hacer tú es que a lo mejor no es lo mismo que tiene que hacer tu vecino”.

“A nosotros principalmente (...) nos puede servir para para acojonar a la Dirección. (...) tú vas al director y dices: ‘oye, que tengo que cumplir esto’ y nadie te dice nada”.

SOBRE LA NIS2:

- **APENAS SE CONOCE EL CONTENIDO DE LA DIRECTIVA NIS2.**
- **SE ESPERA QUE LA NIS2 OBLIGUE A INVERTIR EN CIBERSEGURIDAD.**



Muchas de las entidades desconocen cuál será su clasificación en virtud de la NIS2, si “entidad esencial” o “entidad importante”. Muchas veces **confunden el concepto “esencial” con “crítica”**. En parte, ello se debe a que la mayoría **no ha recibido asesoramiento externo ni ha realizado una auditoría interna** para valorar cómo les afecta la NIS2.

“¿Para qué me vaya a poner yo ahora a hacer nada si no tengo las directrices claras? (...) Es una directriz que tiene que venir (...) del Gobierno y luego, y si no la hace el Gobierno, pues no puede pretender que todo el mundo esté listo cuando digan: ‘ya la hemos hecho’”.

En todo caso, es indudable que **las exigencias de la NIS2 respecto a los contratos con terceros pueden tener repercusiones importantes**, ya que eso obligará a las entidades a **extender la responsabilidad a los proveedores**, y plantea la duda de hasta dónde debe realizarse un control del cumplimiento de los requisitos por parte de éstos. Otra de las posibles consecuencias de la NIS2 puede ser **el encarecimiento del servicio**.

“Al final van a tener que exigir a sus proveedores y por tanto esto se va a transmitir a lo largo de la cadena”.

“En el mundo del agua no es tan fácil trasladar al cliente final. (...) Hay una sensibilidad muy grande en la ciudadanía cuando vamos al tema de la calidad del agua también, pero cuando hablamos del tema de ciberseguridad no lo asocian al mundo del agua”.

CUMPLIMIENTO NORMATIVO: RESUMEN.

- ⇒ Las principales normas aplicables son el ENS, el RGPD y la NIS2.
- ⇒ No se conoce bien el contenido de la Directiva NIS2.
- ⇒ No se han evaluado las acciones necesarias para cumplir con la NIS2.
- ⇒ La Directiva NIS2 puede:
 - ser una oportunidad para justificar medidas de ciberseguridad.
 - afectar de manera significativa a los contratos con terceros.
 - implicar el encarecimiento del servicio.



4.3. Retos de futuro. ¿Cómo mejorar la ciberseguridad hídrica?

Las entidades del sector del agua tienen **pocos foros para compartir dudas e inquietudes** sobre su actividad. Uno de ellos parece ser la **AEAS**, que mencionan como un buen foro de intercambio de experiencias y buenas prácticas, especialmente en el ámbito del comité 8, de ciberseguridad.

“En el mundo de la ciberseguridad todavía hay mucho recelo de compartir información entre empresas” (...) Y... yo creo que aquí tenemos que alinearnos”.

La ciberseguridad en general, y la del sector del agua en particular, se enfrentarán a **nuevos retos y mayores riesgos** en los próximos años, que vendrán de la mano del **incremento de conectividad IT-OT**, lo que tendrá un efecto directo en la vulnerabilidad de todo el ciclo. Se incrementará la **superficie de exposición** al aumentar el **control de elementos realizado con dispositivos móviles**, lo que hará más difícil la gestión. La **Inteligencia Artificial** será un factor facilitador de ataques más sofisticados y difíciles de detectar.

“Cada vez es más difícil darte cuenta que te están atacando”.

“Ese alto grado de digitalización, no siendo bien gestionado, no teniendo presente la ciberseguridad desde el principio, puede dar más problemas que beneficios”.

“No hemos tenido hasta ahora ningún ciberataque (...) a temas de OT o temas específicos de agua, pero también sé que es cuestión de tiempo. (...) no sabemos cuánto tiempo pasará, pero lo intentarán”.

EN LOS PRÓXIMOS AÑOS, LOS RIESGOS:

- **SERÁN MAYORES, Y LOS ATAQUES MÁS SOFISTICADOS.**
- **INVOLUCRARÁN EL USO DE LA INTELIGENCIA ARTIFICIAL (IA).**
- **SE EXTENDERÁN CON IGUAL GRAVEDAD AL ENTORNO OT.**

Para **enfrentarse a los retos** de ciberseguridad y **mejorar la gestión**, es imprescindible realizar **auditorías externas** para conocer exactamente cuál es la situación, dar relevancia a la materia creando un **departamento específico con los recursos necesarios** y consolidar una **cultura de ciberseguridad**: en la organización en general, con **especial énfasis en el personal directivo** (como agentes de toma de decisiones) y **a nivel de usuario**, que es “el eslabón más débil de la cadena”. La **formación** debe ser constante y, por encima de todo, **la Dirección de las entidades debe priorizar la ciberseguridad** en la asignación de recursos al diseñar los planes estratégicos.



Como sugiere uno de los participantes, tal vez una de las medidas que podría contribuir a una mejor gestión de la ciberseguridad hídrica sería que el CCN-CERT publicara un **perfil de cumplimiento específico para el sector**.

“La Dirección es la que (...) va a tener que responder en caso de un incidente”.

“El directivo de más alto nivel de la organización tiene que entender que la ciberseguridad es un tema que él debe dirigir en primera persona”.

5. Conclusiones y recomendaciones

El análisis de las entrevistas realizadas nos permite destacar los siguientes aspectos:

CONCLUSIONES

- ⇒ Los ciberataques más temidos son los de *ransomware*, que también se encuentran entre los más frecuentes.
- ⇒ Los ataques potencialmente más graves son los que pueden comprometer el suministro o la calidad del agua.
- ⇒ El usuario es el principal vector de entrada, generalmente involuntario, de amenazas.
- ⇒ El entorno OT es el más desprotegido, cosa que puede afectar la integridad de la cadena de suministro.
- ⇒ Las entidades han incrementado mucho su ciberseguridad en los últimos 5 años, y lo seguirán haciendo.
- ⇒ Es necesario invertir más en ciberseguridad, sobre todo en cuanto a:
 - Soluciones de ciberseguridad (contando con asesoramiento para decidir).
 - Formación y concienciación de los empleados, incluyendo a los directivos.
- ⇒ La Directiva NIS2 puede implicar cambios importantes en la gestión de la ciberseguridad, pero la mayoría de entidades no conocen cómo les afectará.
- ⇒ Los ataques futuros se extenderán a las infraestructuras OT, utilizarán la Inteligencia Artificial y serán más peligrosos.



RECOMENDACIONES

⇒ Para mejorar la ciberseguridad y enfrentarse a estos retos, es importante:

- realizar auditorías externas,
- crear un departamento específico de ciberseguridad y dedicarle recursos,
- consolidar una cultura de ciberseguridad
- concienciar al usuario,
- formarse continuamente, y
- sobre todo, que la Dirección priorice la ciberseguridad en el plan estratégico.

El sector del agua es un sector crítico cuyas vulnerabilidades a nivel de ciberseguridad pueden tener repercusiones muy graves en las vidas de los usuarios, en su economía y en la de las entidades del sector, en la reputación de las mismas y, especialmente, en la salud pública. Los profesionales de este ámbito son plenamente conscientes de la necesidad de realizar una inversión que, como mínimo, permita abordar el avance en digitalización con las garantías requeridas. La transposición de la Directiva NIS2 y los requisitos de la misma pueden ser una buena oportunidad para justificar inversiones en ciberseguridad que de otro modo tal vez no se producirían, o se dilatarían mucho en el tiempo.

La clave desde el principio y, según podemos deducir de las opiniones expresadas, en todos los puntos del proceso, es la concienciación por parte de la Dirección de las entidades. En una fase inicial, para contemplar la ciberseguridad como prioritaria en los planes estratégicos, y en etapas posteriores para trasladar a todos los trabajadores el compromiso con una tarea permanente de formación, concienciación y actuación, porque como decía uno de los participantes, se trata de *“un proceso largo si se quiere hacer bien hecho”*.